

Legal Risk Brief - Penetration Test Authorization

To: Client

From: Governance Consultant

Date: April 27, 2026

Subject: Phase 1 Legal Risk Brief: Red Lines for Cyber Testing

Purpose

A penetration test is lawful only when the tester has clear, written authorization, stays inside the defined scope, and avoids activity that damages systems, steals data, or disrupts services. The federal Computer Fraud and Abuse Act (CFAA), 18 U.S.C. § 1030, and Washington Cybercrime Act, RCW 9A.90, both create criminal and civil risk when testing goes beyond permission.

Risk Ledger: Actions That Are Illegal Without Authorization

Risk	Why it matters in a test
1. Unauthorized access	Logging into, scanning behind authentication, or entering a system not listed as in-scope may be treated as access without authorization or exceeding authorized access under the CFAA.
2. Obtaining protected information	Copying emails, client files, credentials, financial records, or database contents can trigger CFAA liability when access is unauthorized or beyond the client-approved purpose.
3. Intentional damage or service interruption	Sending code, commands, exploit payloads, or heavy traffic that crashes, degrades, or alters a protected computer can create liability for damage and loss; Washington separately criminalizes electronic data service interference.
4. Password or access-token trafficking	Sharing, selling, reusing, or retaining passwords, API keys, session tokens, or similar access information can be illegal when done with intent to defraud or enable unauthorized access.
5. Data tampering, malware, or spoofing	Altering data in transit, planting malware, impersonating another organization/person, or manipulating identifying information can violate Washington cybercrime provisions and exceed normal test authorization.

State vs. Federal Difference

The CFAA focuses on unauthorized access to a "protected computer," a broad federal category that usually includes internet-connected business systems. Washington law is narrower in one important respect: RCW 9A.90.030 defines "without authorization" as knowingly circumventing technological access barriers to obtain information without permission, and it expressly excludes mere violations of an acceptable-use policy, terms of service, or similar contract. Washington also excludes qualifying white-hat security research from that definition.

Liability Mitigation: Indemnification

Indemnification is a contract promise that one party will defend and reimburse another for specified claims, losses, fines, legal fees, or third-party damages. A tester protects themselves by requiring a signed Rules of Engagement and authorization letter before testing, plus an indemnification clause stating that the client will defend and hold the tester harmless for accidental outages or claims caused by authorized, in-scope testing performed with reasonable care. The clause should not protect reckless, intentional, out-of-scope, or criminal conduct; it should pair with insurance, emergency contacts, logging, data-minimization, and a stop-test procedure.

Recommended Authorization Controls

Before testing begins, require written scope, approved dates and times, allowed tools, excluded methods such as DDoS or social engineering, emergency shutdown authority, data handling rules, and named client contacts who can verify permission in real time.

Sources: 18 U.S.C. § 1030, Computer Fraud and Abuse Act; RCW 9A.90.030, .040, .060, .080, .100, Washington Cybercrime Act; IT-157 project brief, Phase 1 instructions.